



FedRAMP® Security Assessment Plan (SAP)

for Marcus

T-Pot O&G Threat Intelligence Honeypot Lab

Version 1.0

08/12/2026



info@fedramp.gov

fedramp.gov

TEMPLATE REVISION HISTORY

Date	Version	Pages	Description	Author
06/06/2014	2.0	All	Major revision for Special Publication (SP) 800-53 Revision 4. Includes new template and formatting changes.	FedRAMP PMO
		All	Reformatted to FedRAMP Document Standard, added repeated text schema, and content fields to tables that were not Control Tables. Revised cover page, changed document designation to Confidential Unclassified Information (CUI), Removed front matter section How This Document is Organized.added repeated text schema, and content fields to tables that were not Control Tables. Revised cover page, changed document designation to Confidential Unclassified Information (CUI), Removed front matter section How This Document is Organized.	FedRAMP PMO
01/20/2016	3.0		Converted to standard document template Removed Acronyms and referenced FedRAMP Glossary and Acronyms resource document Clarity edits, and instructions for the new Integrated Inventory Template Section 2.2	FedRAMP PMO
			Renamed document from "Security Assessment Plan (SAP) Template to "FedRAMP Security Assessment Plan	FedRAMP PMO

			(SAP) Template”	
10/21/2016	3.1		Updated logo	FedRAMP PMO
06/30/2023	4.0	All	Initial publication after combining the Initial and Annual SAP templates. New template can also be used for Significant Change Requests.	FedRAMP PMO

How to contact us

For questions about FedRAMP, or for questions about this document including how to use it, contact info@FedRAMP.gov.

For more information about FedRAMP, see www.FedRAMP.gov.

Prepared by

Identification of Organization that Prepared this Document	
Organization Name	Marcus (Independent Researcher)
Street Address	N/A — personal lab, address withheld
Suite/Room/Building	N/A
City, State Zip	N/A

Prepared for

Identification of Cloud Service Provider	
Organization Name	N/A — self-directed personal research project; no specific CSP customer organization.
Street Address	N/A — personal lab, address withheld
Suite/Room/Building	N/A
City, State Zip	N/A

Document Revision History

This is an initial assessment of the T-Pot O&G Threat Intelligence Honeypot Lab.

T-Pot O&G Threat Intelligence Honeypot Lab does not leverage any FedRAMP-authorized services from another Cloud Service Provider. This system is a standalone Azure IaaS deployment.

Table Assumptions-1 Leveraged Systems CSP/CSO

FedRAMP Package ID	Marcus	T-Pot O&G Threat Intelligence Honeypot Lab

1.1 Location of components

All in-scope components reside within a single Azure resource group (Microsoft Azure, East US region), consisting of one Ubuntu Linux VM, an associated Virtual Network/subnet, Network Security Group, static public IP, Key Vault, and Log Analytics workspace. There are no on-premises components and no other cloud regions in scope.

1.2 IP Addresses Slated for Testing

One (1) static public IP address assigned to the honeypot VM (redacted from this public-facing document for operational security; on file with the system owner). Internal/private VNet addressing is also in scope for credentialed local checks.

1.3 Role Testing Exclusions

Not applicable. This is a single-operator lab with no distinct user roles to test.

1.4 Role Testing for Significant Change Requests

Not applicable. No Significant Change Request has been filed against this system; it has since been decommissioned.

2 Assumptions

The assessor and system owner are the same individual, which is a departure from the independence FedRAMP normally requires between a CSP and its 3PAO; this is disclosed here rather than obscured, consistent with the lab/demonstration scope of this system.

The honeypot's intentionally-exposed decoy services (see SSP Section 4) are assumed to be operating as designed unless evidence suggests otherwise; findings against those services are evaluated for fitness against that design intent rather than treated as unconditional vulnerabilities.

The system has since been decommissioned; this SAP is retained as the historical record of the methodology used during its operational lifecycle.

3 Methodology

3.1 Control Testing

Control testing follows a hybrid Examine/Test methodology consistent with NIST SP 800-53A: automated compliance scanning (OpenSCAP CIS Level 2 benchmark), authenticated vulnerability scanning (Tenable Nessus, credentialed), and manual examination of configuration files (sshd_config, sysctl hardening baseline, NSG rule set, Key Vault encryption status, fail2ban jail configuration, logrotate policy) against the control implementations documented in the SSP.

3.2 Data Gathering

Evidence is gathered directly from the live system (scan output, configuration file contents, Azure Portal control settings) rather than through interview, given the single-operator context of this lab.

3.3 Sampling

Not applicable. Given the small scope (one host), all in-scope components are assessed in full rather than sampled.

3.4 Penetration Test

No formal penetration test was performed. The system's own function as a honeypot means it is, by design, continuously exposed to real-world unauthenticated attack traffic from the internet, which serves an analogous purpose to a black-box external test; this traffic is captured and analyzed as part of the system's core research purpose rather than as a discrete assessment activity.

4 Test Plan

The security assessment team, points of contact, testing schedule, and testing tools used are described in the sections that follow.

4.1 Security Assessment Team

Marcus — System Owner and Assessor. In a production FedRAMP engagement this role would be split between the CSP and an independent Third Party Assessment Organization (3PAO); for this lab-scale demonstration system, the same individual performs both roles, as disclosed in the Assumptions section above.

4.2 CSP Testing Points of Contact (POCs)

Marcus — single point of contact for all testing activity.

4.3 Testing Performed Using Automated Tools

OpenSCAP (CIS Ubuntu Linux 22.04/24.04 Benchmark, Level 2 profile) — configuration compliance scanning.

Tenable Nessus (credentialed/authenticated scan, Basic Network Scan policy, CVSS v3.0 severity base) — vulnerability scanning.

4.4 Testing Performed Using Manual Methods

Direct examination of sshd_config, sysctl hardening configuration, Azure NSG rule set, Key Vault disk-encryption status, fail2ban jail status, and logrotate policy against the SSP's documented control implementations.

4.5 Schedule

OpenSCAP CIS Level 2 audit — completed.

Nessus credentialed scan — completed.

Manual control examination (NSG, sshd, Key Vault, fail2ban) — completed, folded into the Security Assessment Report (SAR).

Follow-up Nessus re-scan to verify remediation — completed (passed, zero vulnerabilities reported) prior to system decommissioning.

5 Rules of Engagement

The ROE is a document designed to describe proper notifications and disclosures between an owner of a tested system and an IA. In particular, a ROE includes information about targets of automated scans and IP address origination information of automated scans (and other testing tools). Together with the information provided in preceding sections of this document, this document shall serve as a ROE once signed.

5.1 Disclosures

Any testing will be performed according to the terms and conditions, cited in this SAP and the Penetration Testing ROE, once this SAP is signed by both parties. These ROEs must be upheld to minimize risk exposure that could occur during security assessment testing.

The following sections provide additional disclosures accepted by the IA and the CSP for proceeding with this Security Assessment.

5.1.1 Security Testing May Include

Automated vulnerability and compliance scanning of the in-scope VM.

Manual review of configuration files and Azure resource settings.

Observation and analysis of unsolicited inbound traffic to the honeypot's intentionally-exposed decoy services (this is the system's normal operating function, not a distinct offensive test).

5.1.2 Security Testing Will Not Include

Testing of any Azure platform services, hypervisor, or other tenants — out of scope per the shared responsibility model.

Denial-of-service testing.

Social engineering or physical security testing (not applicable — no personnel or facility in scope).

5.2 End of Testing

Testing activities concluded with a final Nessus credentialed re-scan performed to verify remediation status, after which the system was decommissioned.

5.3 Communication of Test Results

Results are documented in the accompanying Security Assessment Report (SAR) and summarized for non-technical review in an Executive Report.

5.4 Limitation of Liability

This assessment was performed by the system owner against their own personal lab system for research and professional-development purposes. It does not constitute a FedRAMP authorization, a formal third-party assessment, or a warranty of security for any other system or deployment.

6 Signatures

Marcus — System Owner / Assessor — 08/12/2026

Appendix A FedRAMP T-Pot O&G Threat Intelligence Honeypot Lab Security Controls Selection Worksheet

N/A — this worksheet tracks per-control tailoring decisions across a full 800-53 baseline for a multi-tenant CSP offering; the SSP's Control Implementation Summary (Section 3) covers this system's implemented controls directly, at a scope appropriate to a single-VM lab.

Appendix B Sampling Methodology

N/A — no sampling was performed; see Methodology, Sampling (above). All in-scope components were assessed in full.

Appendix C Penetration Testing Plan and Methodology

N/A — no formal penetration test was performed; see Methodology, Penetration Test (above) for rationale.

Appendix D Significant Change Request Documentation

N/A — no Significant Change Request was filed against this system during its operational lifecycle.